

DFIR LAB-4 : Advanced Email Forensics

**Eshan
K027**

1.1 Comprehensive Intelligence Gathering Framework

A structured approach is essential for gathering intelligence on email threats. This framework encompasses multiple layers of data collection, correlation, and analysis to uncover malicious activities linked to email-based threats.

1.2 Multilayered OSINT Intelligence Collection

OSINT (Open-Source Intelligence) collection for email threat intelligence involves leveraging diverse data sources and analytical methods to assess email-based risks comprehensively.

Primary Intelligence Vectors:

1. Digital Footprint Analysis

Email threat actors often leave digital traces that can be analyzed to detect suspicious activities and infrastructure.

- **Comprehensive domain reputation tracking**
 - Evaluating sender domain credibility using reputation services like MXToolbox, Cisco Talos, and Google Safe Browsing.
 - Detecting domain age, WHOIS history, and associated IP addresses.
 - Identifying typo-squatting, homoglyph domains, and lookalike domain tactics.
- **Historical infrastructure mapping**
 - Tracking past IP resolutions and infrastructure changes using services like RiskIQ and PassiveTotal.
 - Assessing previous hosting environments and detecting shifts in attack patterns.
- **Passive DNS reconnaissance**
 - Analyzing historical DNS records to trace past domain associations.
 - Identifying shared hosting environments linked to known malicious domains.
 - Extracting subdomain information to assess attack vectors.
- **SSL/TLS certificate investigation**
 - Examining SSL certificate transparency logs for domain usage history.
 - Detecting self-signed or short-lived certificates often used by threat actors.
 - Cross-referencing certificate issuers and expiration patterns for suspicious activities.

2. Threat Intelligence Correlation

Correlating multiple threat intelligence sources enhances detection accuracy and enables real-time threat mitigation.

- **Cross-referencing multiple threat databases**
 - **VirusTotal** – Aggregates antivirus scan results and domain reputation indicators.
 - **AbuseIPDB** – Tracks reported malicious IP addresses involved in email-based attacks.
 - **ThreatCrowd** – Provides email infrastructure visualizations and link analysis.
 - **Hurricane Electric IP lookup** – Offers detailed ASN and routing information for tracing attack origins.
 - **Dark web and underground forum monitoring**
 - Identifying leaked email credentials from breached databases.
 - Monitoring discussions about email phishing kits and spam botnets.
 - Tracking emerging email-based malware campaigns.
 - **Threat actor infrastructure tracking**
 - Profiling adversaries based on observed TTPs (Tactics, Techniques, and Procedures).
 - Mapping attack infrastructure using data from previous email phishing campaigns.
 - Detecting reused hosting services, VPNs, and bulletproof servers.
-

Advanced Data Extraction Techniques

Sophisticated Forensic Data Formats:

Investigating emails requires handling multiple forensic data formats, ensuring compatibility with forensic tools.

- **.mbox** – Standard mailbox archive format storing multiple email messages.
- **.mbx** – Microsoft Outlook Express mailbox storage format.
- **.emlx** – Apple Mail email format, typically storing single email messages.
- **.ipm** – IBM Notes proprietary email storage format.
- **Encrypted container formats (.7z, .veracrypt)** – Commonly used for concealing email-related forensic evidence.

Extended Forensic File Type Analysis:

Additional forensic artifacts provide deeper insights into email-related threats.

- **Email-related forensic artifacts** – Includes email headers, body content, and attachments.
- **System memory dumps** – Capturing volatile memory to recover decrypted emails and active attack artifacts.
- **Network forensic captures** – Analyzing email traffic for suspicious activities using PCAP (Packet Capture) files.
- **Encrypted communication logs** – Investigating logs from encrypted email services like ProtonMail and Tutanota.

- **Browser history and cache files** – Identifying email-based phishing interactions.
 - **Cloud storage synchronization logs** – Detecting exfiltrated email data stored in services like Google Drive or OneDrive.
-

1.2 Advanced Email Forensic Data Collection Methodology

Evidence Acquisition Protocol

A structured forensic methodology ensures accurate collection, preservation, and analysis of email-based evidence.

1. Forensic Preparation

- **Establish forensic workstation with write-blockers**
 - Prevents modification of digital evidence during extraction.
- **Configure isolated network environment**
 - Ensures malware samples cannot communicate externally during analysis.
- **Prepare multi-factor evidence documentation**
 - Logs investigator actions, timestamps, and procedural integrity.
- **Initialize forensic imaging and chain of custody tracking**
 - Maintains evidence integrity with cryptographic verification.

2. Metadata Extraction and Preservation

Extracting and securing metadata is critical for tracking email-based threats.

- **Utilize advanced metadata extraction frameworks**
 - Employ tools like ExifTool, Emailchemy, and CyberChef for metadata analysis.
- **Implement cryptographic hash validation (MD5, SHA-256, SHA-3)**
 - Ensures data integrity and prevents tampering.
- **Capture granular timestamp information**
 - Extracts email send/receive timestamps, IP resolution times, and forensic event timelines.
- **Extract embedded metadata from attachments**
 - Recovers hidden EXIF data, document metadata, and potential execution payloads.

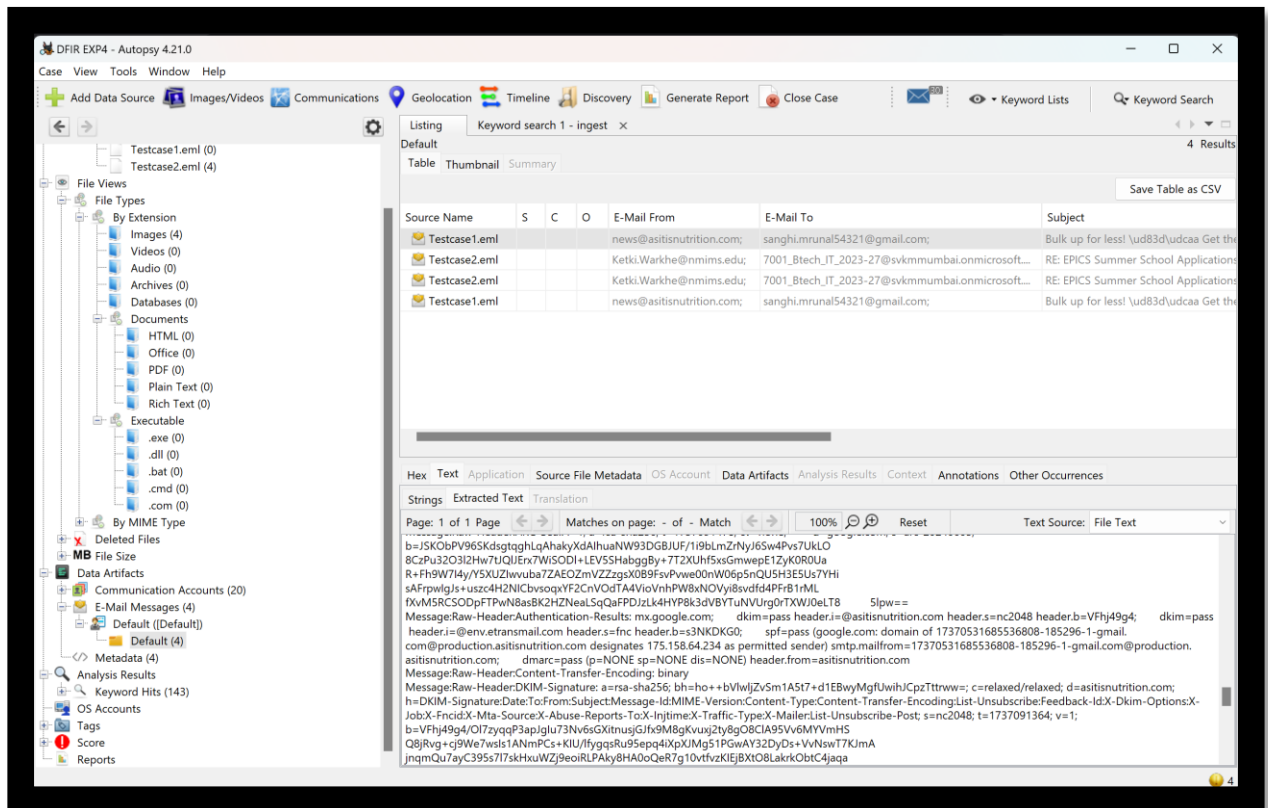
3. Deep Forensic Artifact Collection

Comprehensive data acquisition allows forensic teams to reconstruct email attacks.

- **Full-system volatile memory acquisition**
 - Recovers active email session data, decryption keys, and malware payloads.
- **Complete email server log collection**
 - Retrieves logs from SMTP, IMAP, POP3, and Exchange servers.
- **Network traffic comprehensive capture**
 - Captures email transactions, TLS handshake data, and suspicious email transfers.
- **Cloud service synchronization log extraction**

- Analyzes cloud email services (e.g., Google Workspace, Microsoft 365) for unauthorized data access.
- **Endpoint detection and response (EDR) telemetry**
 - Monitors email-based attack behaviors and correlates with endpoint activities.

2.1 Comprehensive Header Intelligence Analysis



Forensically Significant Header Elements

1. Authentication Mechanisms

Email authentication technologies validate sender legitimacy, detect impersonation, and mitigate spoofing or phishing attempts.

- **SPF (Sender Policy Framework) deep analysis**
 - Verifies whether the sending IP address is authorized by the domain's SPF record.
 - Evaluates SPF mechanisms (include, a, mx, ptr, ip4, ip6, exists, redirect) for inconsistencies.
 - Detects SPF record soft failures (~all) vs. strict rejections (-all).
 - Identifies SPF flattening techniques used by attackers to evade detection.
- **DKIM (DomainKeys Identified Mail) cryptographic validation**
 - Checks the cryptographic signature applied to the email body and headers.
 - Verifies DKIM selector validity and corresponding DNS TXT records.
 - Detects DKIM misconfigurations that may allow spoofing.
 - Identifies forged or missing DKIM signatures, common in phishing campaigns.

- **DMARC (Domain-based Message Authentication) policy interpretation**
 - Examines policy enforcement (none, quarantine, reject).
 - Determines alignment between SPF, DKIM, and the sending domain.
 - Analyzes forensic DMARC reports for unauthorized email senders.
 - Detects domain impersonation and BEC (Business Email Compromise) tactics.
 - **ARC (Authenticated Received Chain) trace analysis**
 - Evaluates email re-authentication in forwarding scenarios.
 - Identifies tampered ARC headers that could indicate email relay abuse.
 - Determines if an intermediary has altered email authentication results.
 - Assesses ARC policy impact on email deliverability and security.
-

2. Advanced Routing Intelligence

Email routing analysis helps reconstruct the transmission path, identify obfuscation tactics, and infer the true origin of an email.

- **Comprehensive "Received:" header trace reconstruction**
 - Tracks email journey from sender to recipient.
 - Detects anomalies in SMTP relay chains, such as unexpected intermediaries.
 - Cross-references timestamps to identify time-skewing attacks.
 - **Hop-by-hop transmission path visualization**
 - Constructs a visual representation of email traversal across networks.
 - Pinpoints anomalous hops that indicate relay hijacking or unauthorized forwarding.
 - Analyzes server response times to detect potential latency manipulation.
 - **Network topology inference**
 - Maps the sender's infrastructure based on email header IPs.
 - Determines whether the sender operates from a shared or dedicated email server.
 - Identifies hosting services (e.g., AWS, Azure, DigitalOcean) used by the sender.
 - **Anonymization and obfuscation detection**
 - Identifies routing through anonymization services (VPNs, TOR, proxies).
 - Detects domain fronting techniques used to disguise the real sender.
 - Flags unusual transmission behaviors, such as rapid multi-region hops.
-

3. Cryptographic Signature Analysis

Cryptographic email authentication mechanisms ensure email integrity and authenticity. Attackers often attempt to bypass or forge these signatures.

- **Public Key Infrastructure (PKI) validation**
 - Verifies certificates used for email encryption and signing.
 - Checks certificate expiration, validity, and issuing CA (Certificate Authority).
 - Identifies weak cryptographic algorithms (e.g., deprecated SHA-1).
 - Detects certificate misuse or fraudulent issuance.
- **S/MIME certificate examination**
 - Analyzes X.509 certificate details embedded in S/MIME emails.

- Detects revoked, expired, or self-signed certificates.
 - Examines S/MIME signature integrity to detect tampering attempts.
 - **PGP/GPG signature verification**
 - Validates OpenPGP digital signatures on encrypted email content.
 - Extracts associated key fingerprints and checks trust levels.
 - Identifies weak PGP keys that may be susceptible to cryptographic attacks.
 - **Authentication token analysis**
 - Examines email authentication headers for OAuth-based email transmission.
 - Identifies tokens used for email-based API abuse.
 - Detects token reuse or hijacking attempts.
-

Forensic Header Deconstruction Methodology

Extracting actionable intelligence from email headers requires a methodical approach to identify anomalies, spoofing attempts, and transmission inconsistencies.

Detailed Header Intelligence Extraction

- **Sender address canonicalization**
 - Normalizes sender email addresses to detect subtle variations (e.g., homoglyph attacks).
 - Identifies free email service abuse (e.g., fake Gmail or Outlook sender addresses).
 - Detects spoofed "From" addresses that deviate from the Return-Path header.
 - **IP geolocation and reputation scoring**
 - Maps sender IPs to geographical locations to detect inconsistencies.
 - Cross-references sender IP with known blacklists and threat intelligence feeds.
 - Detects unusual IP locations that indicate compromised accounts or VPN masking.
 - **Network infrastructure fingerprinting**
 - Identifies email service providers based on header metadata.
 - Assesses whether the email originates from a known spam relay.
 - Extracts ASN (Autonomous System Number) details to infer network ownership.
 - **Transmission anomaly detection**
 - Compares timestamp inconsistencies across multiple Received headers.
 - Identifies mismatched email metadata (e.g., conflicting time zones).
 - Detects unusual relay delays indicative of email interception attempts.
 - **Potential spoofing indicator identification**
 - Flags missing or malformed authentication headers.
 - Detects discrepancies between HELO/EHLO and originating IP addresses.
 - Identifies forged Return-Path headers often used in phishing campaigns.
-

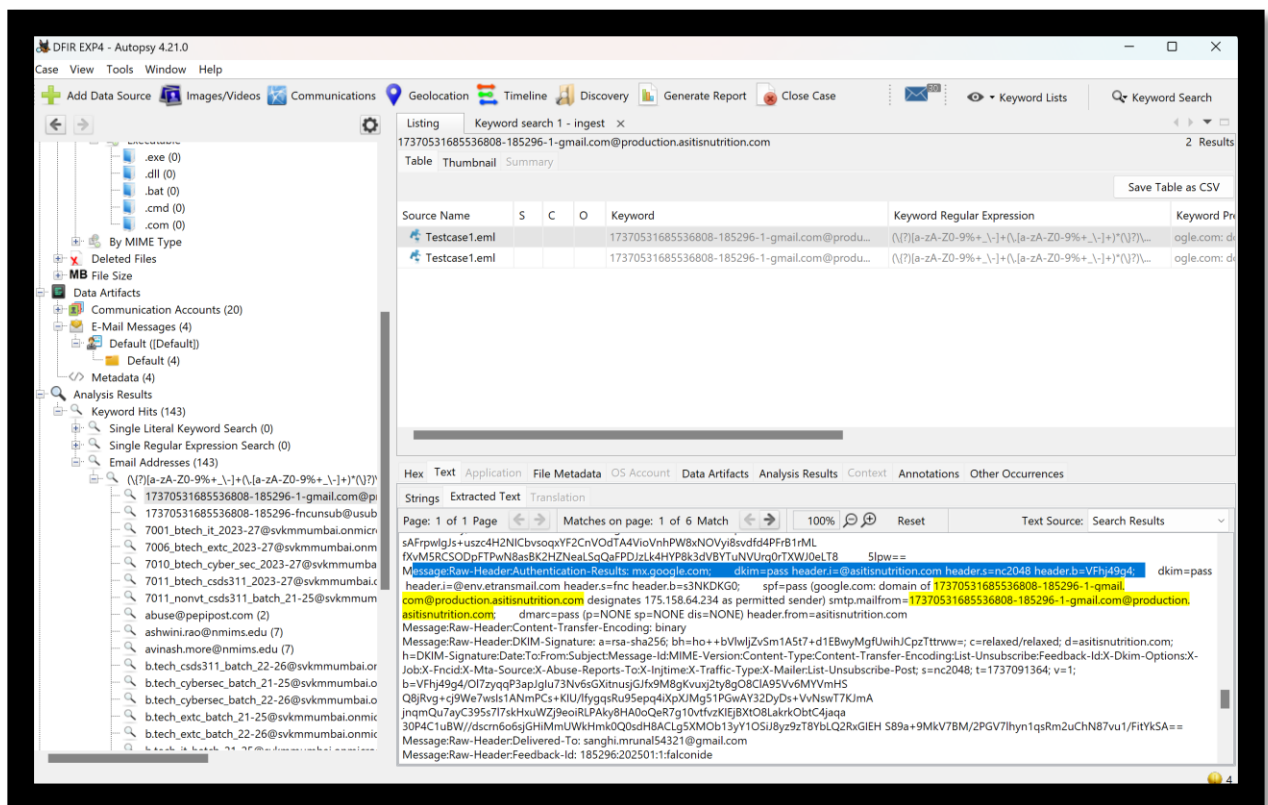
2.2 Advanced Threat Indicator Correlation

Email threat intelligence is enhanced by correlating multiple indicators to detect sophisticated attack campaigns.

Threat Intelligence Correlation Matrix

- **Sender domain age and reputation**
 - New domains often indicate disposable phishing setups.
 - Correlates with WHOIS data to track domain ownership history.
 - Flags domain reputation using services like Cisco Talos and DomainTools.
- **Historical IP address blacklist entries**
 - Checks if sender IP has been blacklisted in the past.
 - Cross-references IP reputation using Spamhaus, Project Honey Pot, and AbuseIPDB.
 - Identifies recurring IP-based email attacks.
- **Geopolitical infrastructure analysis**
 - Maps sender origin against known threat actor regions.
 - Detects email traffic originating from high-risk geographies.
 - Correlates with geopolitical cyber threat reports.
- **Known threat actor infrastructure mapping**
 - Matches sender IPs, domains, and ASN data against known threat actor infrastructures.
 - Tracks reused email attack patterns across multiple campaigns.
 - Identifies APT (Advanced Persistent Threat) group TTPs (Tactics, Techniques, and Procedures).
- **Machine learning-based anomaly detection**
 - Utilizes AI-driven analysis to detect deviations from normal email behavior.
 - Identifies linguistic patterns in phishing email bodies.
 - Detects sender impersonation attempts through behavioral analysis.

3. Advanced Digital Forensics and Incident Response (DFIR) Techniques



1. Email Headers

What are they?

Email headers contain metadata about the email's journey from the sender to the recipient. They include:

- Sender and recipient addresses
- Sending and receiving mail servers (via "Received" fields)
- Timestamp of transmission
- Authentication details (SPF, DKIM, DMARC)

Tools and Techniques for Email Header Analysis:

- **Manual Extraction:**
 - **Outlook/Gmail:** Open the email > View message source or show original.
 - Copy the email header for analysis.
 - **Analysis Tools:**
 - **MxToolbox Email Header Analyzer:** Extracts and analyzes the headers for path tracing, delay analysis, and identifying spoofed emails.
 - **Mailheader.org:** Decodes email headers and displays routing and authentication checks.
 - **Wireshark (Network Packet Analysis):** Can capture SMTP traffic to extract email headers directly from the network.
-

2. Email Logs

What are they?

Logs from mail servers (e.g., Postfix, Exchange, or Sendmail) document email transactions, including sender/recipient IPs, timestamps, and error codes.

How to Collect and Analyze Logs:

- **Log Collection Locations:**
 - Linux: /var/log/maillog, /var/log/mail.err
 - Windows Exchange Server: Application logs in the Event Viewer or the MessageTrackingLog folder.
- **Log Analysis Tools:**
 - **Logstash (Elastic Stack):** Ingests email logs for searching and filtering.
 - **Splunk:** Collects and indexes logs for deeper pattern analysis.
 - **Syslog Parsers (e.g., Fluentd):** Collect and normalize logs from multiple mail servers.

What to Look For in Logs?

- Failed delivery attempts (indicating possible attacks like phishing or spoofing).
 - Connections from suspicious IP addresses.
 - Timestamps and unusual frequency of emails from one user (evidence of account compromise).
-

3. Full Email Content

Why It's Important:

Analyzing the full email (with attachments) is necessary to:

- Extract malicious links or attachments.
- Verify authenticity (check DKIM signatures or compare email content with headers).
- Determine whether the email is part of a phishing or fraud attempt.

Forensic Tools for Email Content:

- **FTK Imager (AccessData):**
 - Extracts full email data from PST/OST files (common email archive formats).
- **Email Forensic Tools:**

- **Magnet AXIOM:** Supports analysis of email archives (PST, OST) and can link emails to other evidence like browser activity.
 - **X1 Social Discovery:** Collects and analyzes emails, attachments, and links, especially useful for compliance and legal cases.
 - **EnCase (OpenText):** Extracts email data from raw disk images.
 - **Threat Analysis:**
 - Use **YARA rules** to detect malicious patterns in email attachments or embedded links.
 - Perform **sandbox testing** for suspicious attachments using tools like **Cuckoo Sandbox** or **Hybrid Analysis**.
-

4. Network Traffic Analysis

Why It's Useful:

If email content is suspected to have been sent or received during an incident, network traffic logs may provide additional clues:

- Outbound SMTP traffic can indicate email exfiltration.
- DNS lookups for suspicious domains linked to phishing or C2 servers.

Tools for Network Traffic Analysis:

- **Wireshark:**
 - Capture SMTP, POP3, or IMAP traffic for email packets.
 - Filter traffic by port (e.g., tcp.port == 25 for SMTP).
 - **Suricata/Zeek (IDS/IPS):**
 - Logs email-specific traffic for suspicious patterns, such as data exfiltration.
 - **Network Monitoring Tools:**
 - Use **Palo Alto Cortex XDR** or **Microsoft Defender for Office 365** for real-time monitoring of suspicious email-related activities.
-

5. Authentication Checks (SPF, DKIM, DMARC)

Purpose:

Verify if the email was legitimately sent by the claimed domain. This helps identify spoofed emails.

Analysis Process:

- Check SPF Records:
 - Use **dig** command or **MxToolbox SPF Record Lookup** to verify the sender's IP against the domain's SPF policy.
 - Verify DKIM Signatures:
 - Decode the DKIM signature to ensure it matches the claimed domain. Use tools like **dkimvalidator.com**.
 - Analyze DMARC Reports:
 - DMARC aggregate reports provide statistics on emails that passed/failed SPF and DKIM checks. Tools like **DMARCIAN** can parse and analyze these reports.
-

6. Timeline and Correlation Analysis

Purpose:

Combine multiple data sources to reconstruct the timeline of an attack or suspicious activity.

Tools:

- **Plaso/Log2Timeline:** Processes email logs and integrates them with other system logs for timeline generation.

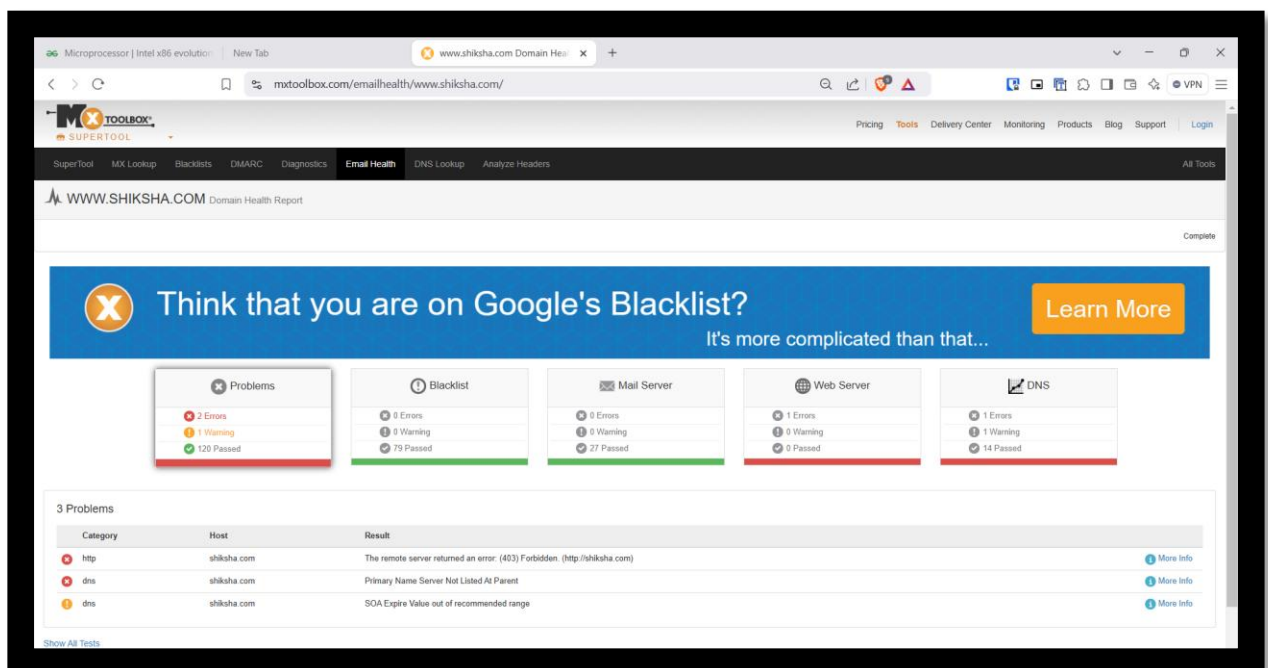
- **Timesketch:** Visualizes email-related events along with other incident artifacts (e.g., file access logs or network traffic).

Steps to Ensure Evidence Integrity

1. **Preserve Original Copies:**
 - Never modify original email files or logs. Make forensic copies for analysis.
2. **Document Chain of Custody:**
 - Record all handling and analysis steps to maintain admissibility in court.
3. **Hashing for Validation:**
 - Use SHA-256 or MD5 to generate hashes of email data to ensure its integrity during analysis.

Challenges and Considerations

- Email spoofing techniques (e.g., fake SPF or DKIM headers) can complicate attribution.
- Advanced phishing attacks may use sophisticated methods to bypass initial authentication checks.
- Full-text analysis of email content may require permission from legal teams or compliance departments to avoid privacy violations.



Observations from the Domain Health Report

1. **Problems Identified:**
 - **2 Errors, 1 Warning, 120 Passed:** This indicates some issues with the domain configuration.
 - **Errors:**
 - **Remote Server Returned an Error (403):** This means that the web server for **shiksha.com** is denying access to requests, possibly due to incorrect permissions or security settings.
 - **Primary Name Server Not Listed at Parent:** This suggests an issue with DNS delegation, which can lead to resolution problems.
 - **Warning:**

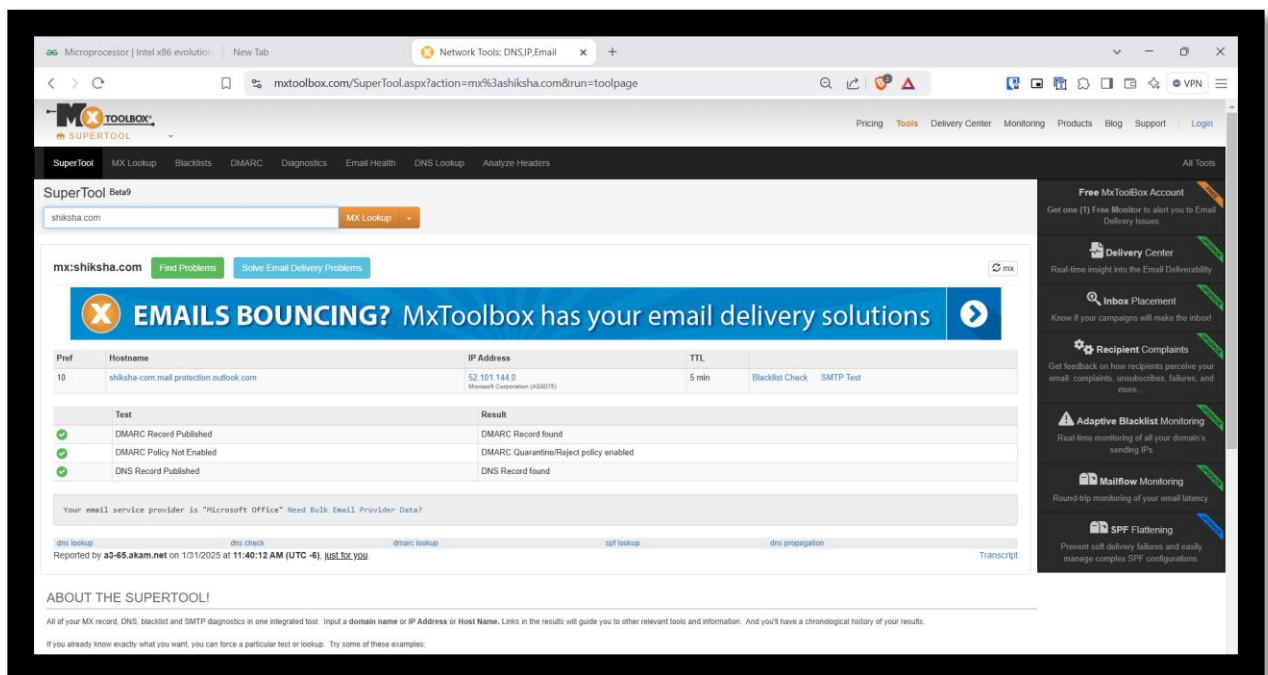
- **SOA Expire Value Out of Recommended Range:** The Start of Authority (SOA) record has an expiration value that is not in the optimal range, which may impact DNS performance.

2. Blacklist Check:

- **No Blacklist Issues:** The domain is not blacklisted, meaning email servers are not flagging emails from this domain as spam.

3. Mail Server, Web Server, and DNS Status:

- **Mail Server:** No major errors, just a warning.
- **Web Server:** One error and one warning, likely related to the access issue (403 error).
- **DNS:** One error and one warning, which can lead to domain resolution problems.



Observations from the MX Lookup and Email Configuration

1. Email Server Configuration:

- **Mail Server Identified:** The email services for **shiksha.com** are hosted on **Microsoft Outlook (protection.outlook.com)**.
- **DMARC Policy Not Enabled:** This means the domain has not fully enforced email authentication policies, which can lead to email spoofing risks.
- **DMARC Quarantine/Reject Policy Not Enabled:** Indicates that emails failing authentication are not being blocked or marked as spam.
- **DNS Record Published:** The domain has valid DNS records.

Conclusion

Advanced email forensics represents a sophisticated intersection of digital investigation, threat intelligence, and cybersecurity analytics. Success demands a holistic, multidisciplinary approach integrating technical expertise, analytical rigor, and comprehensive threat landscape understanding.